O que aconteceu com o PHP?

01 / VISÃO GERAL | PHP2Shell: um problema no próprio PHP que sustenta sites

Risco de ataque mesmo antes do login
Em 21 de outubro de 2026, a equipe do PHP publicou correções para duas vulnerabilidades críticas. Em determinadas condições, um invasor não autenticado pode executar código não autorizado no servidor.

O que é PHP?
Linguagem de programação do lado do servidor usada pelo WordPress e outros sistemas. Gera páginas e processa dados inseridos.

CVE-2026-109618
O tratamento da falta de memória pode deixar dados internos incompletos; operações inválidas de memória podem levar à execução de código.

CVE-2026-109619
Um estado interno antigo ligado à memória liberada pode permanecer e ser usado em uma requisição posterior, podendo levar à execução de código.

Ambas têm gravidade de 9.2 / 10
“Crítica” no CVSS v4.0. O sucesso real do ataque também depende da configuração e dos ajustes.

Reforçar apenas a senha administrativa não resolve a causa do problema.
TODOROKI / SEGURANÇA CIBERNÉTICA / 2026.10.23

Quais são os riscos?

02 / RISCO | Os danos dependem das permissões do PHP e das informações acessíveis

01 Vazamento de informações
Configurações do servidor, credenciais e dados de bancos acessíveis podem ser roubados.

02 Alteração do site
Páginas ou links modificados e formulários falsos também podem prejudicar os usuários.

03 Interrupção do serviço e invasão persistente
Interferir no processamento ou instalar arquivos maliciosos pode paralisar operações ou permitir novas invasões.

Não se limita ao WordPress
A orientação oficial abrange amplamente ambientes PHP que processam requisições web, incluindo PHP-FPM, mod_php do Apache, php-cgi, FrankenPHP e LiteSpeed.

No mod_php, em particular, há demonstrações de ataques que funcionam antes da execução do código da aplicação. Uma tela de login não basta para ficar tranquilo.

São danos possíveis; não significa que todos os sites já foram invadidos.
TODOROKI / SEGURANÇA CIBERNÉTICA / 2026.10.23

A solução fundamental: atualizar o PHP

03 / ATUALIZAÇÃO | Verificar separadamente do núcleo e dos plugins do WordPress

Versões que contêm estas correções
PHP 8.2: 8.2.35
PHP 8.3: 8.3.36
PHP 8.4: 8.4.27
PHP 8.5: 8.5.12

Usar essas versões corrigidas ou posteriores da mesma série, ou pacotes cujo distribuidor tenha aplicado as correções. Não julgar apenas pela versão exibida; consultar também o comunicado do fornecedor.

Verificar → preservar → atualizar → inspecionar
1. Verificar no painel ou com o provedor se PHP é utilizado e o estado das correções.
2. Fazer backup dos arquivos e bancos de dados e verificar compatibilidade.
3. Atualizar PHP, reiniciar processos necessários e verificar atualizações pendentes.
4. Conferir exibição, login, arquivos e comunicações suspeitos.

O suporte regular do PHP 8.1 e anteriores terminou. Consultar o distribuidor sobre correções e avançar para uma série com suporte.

Em hospedagem compartilhada, perguntar: “Estes dois CVEs foram corrigidos?”
TODOROKI / SEGURANÇA CIBERNÉTICA / 2026.10.23

E se não for possível atualizar?

04 / AÇÃO | Medidas temporárias, resposta a incidentes e ações dos usuários

Não considerar apenas medidas temporárias como segurança
Mudanças oficiais de configuração podem reduzir alguns caminhos de ataque, mas apenas a atualização resolve totalmente. Consultar o administrador e considerar restrição de acesso ou suspensão temporária dos serviços afetados.

Não copiar valores de configuração sem avaliar
Desativar o progresso de upload mitiga caminhos específicos. Mudar limites de memória pode afetar a disponibilidade; avaliar todo o ambiente.

Se houver suspeita de invasão, não encerrar na atualização
A versão corrigida não remove arquivos maliciosos já instalados. Preservar logs e evidências e investigar o alcance. Se necessário, restaurar a partir de um ambiente seguro e mudar credenciais.

Usuários devem consultar comunicados oficiais
Cabe ao operador corrigir o servidor. Ler alertas e parar de inserir dados em telas de login ou pagamento incomuns. Seguir os procedimentos anunciados pelo aplicativo oficial ou site oficial conhecido.

“Exibir normalmente” por si só não comprova segurança.
TODOROKI / SEGURANÇA CIBERNÉTICA / 2026.10.23